JS

Jahangir Shukurov | GRC Portfolio

PROJECT 2 | METHODOLOGY

Risk Management Methodology

How Orvanta identifies, scores, treats and accepts information security risk

Client	**Orvanta Payments UAB**
Document ID	**ORV-RISK-001**
Version	**1.0**
Date	**18 December 2026**
Classification	**Confidential (sample)**

Sample engagement — fictional company, prepared for portfolio purposes.

Document control

Field	Value
Document ID	ORV-RISK-001
Title	Risk Management Methodology
Version	1.0
Date	18 December 2026
Author	Jahangir Shukurov
Reviewer	Lukas Jankauskas, Risk Manager
Approver	Ugnė Baltrūnaitė, CEO
Classification	Confidential (sample)

Version history

Version	Date	Author	Change
0.1	9 December 2026	Jahangir Shukurov	Draft for Risk Manager and CISO-designate review
1.0	18 December 2026	Jahangir Shukurov	Approved by the CEO for use

Contents

1 Summary **3**
2 Purpose and scope **3**
3 Roles **3**
4 Process **4**
5 Risk criteria **5**
5.1 Likelihood 5
5.2 Impact 5
5.3 Risk levels and appetite 6
6 Threat-informed analysis **6**
7 Treatment and acceptance **7**
8 Monitoring and review **7**

1 Summary

This document sets one repeatable way to assess information security risk at Orvanta. It replaces the February 2025 spreadsheet, which had no scales, owners or acceptance rules. It is aligned with ISO/IEC 27005:2022 and meets the needs of ISO/IEC 27001:2022 clauses 6.1.2, 6.1.3, 8.2 and 8.3.

- **Business scales.** Likelihood and impact use five levels each. Impact is defined in euros, regulatory consequence, customer effect and payment downtime.
- **Threat-informed.** Risks come from assets and from attack scenarios. Adversarial threats are mapped to MITRE ATT&CK, so likelihood reflects how attackers really work.
- **Three scores per risk.** Inherent, current with existing controls, and target after treatment. The difference shows what controls are worth.
- **Clear appetite.** Scores up to 9 are within appetite. Higher scores need treatment or a signed acceptance by the CEO or the Management Board.
- **Named owners.** Every risk has one accountable owner, and every treatment action has an owner and a date.

Who decides. The Management Board approves the appetite. The CEO approves this method and accepts High risks. Risk owners accept Medium and Low risks.

2 Purpose and scope

The method applies to all information and systems in the ISMS scope: Orvanta Payments UAB, Orvanta Engineering LLC, all products, AWS production, both offices, remote work and suppliers that handle Orvanta data. It covers risks to confidentiality, integrity and availability, plus related regulatory and commercial consequences. Enterprise risks without an information security cause stay in the corporate risk process run by the Risk Manager.

3 Roles

Role	Holder	Responsibility
Management Board	Chaired by Henrik Aalto	Approves risk appetite. Accepts Critical risks as time-limited exceptions. Reviews the risk profile each quarter.
CEO	Ugnė Baltrūnaitė	Approves this method and the treatment plan. Accepts High risks in writing.
Risk Manager	Lukas Jankauskas	Owns the method and the register. Runs workshops and checks scoring is consistent.
CISO-designate	Nino Beridze	Provides threat and control expertise. Maintains the threat catalog and attack scenarios.
Risk owners	Named per risk	Accountable for one risk each: agree scores, choose treatment, accept Medium and Low residual risk.
Asset owners	Named per asset	Rate confidentiality, integrity and availability and keep the asset record current.
DPO and Head of Compliance	Karolis Vaitkus, Eglė Norvilaitė	Advise on privacy and regulatory impact.

4 Process



Figure 1: The risk process. Consultation and review run alongside every step.

Step	What happens	Output
Set context	Confirm scope, criteria and appetite. Refresh the asset register and threat catalog.	Approved criteria
Identify	Find risks two ways: by asset (what could go wrong with this system or data) and by event (how an attack or failure would unfold).	Risk statements with cause, event and consequence
Analyze	Score likelihood and impact at three stages. Record existing controls and their evidence.	Scored register
Evaluate	Compare scores with appetite and rank the risks.	Prioritized risk list
Treat	Choose mitigate, avoid, transfer or accept. Select Annex A controls and plan actions.	Treatment plan and input to the Statement of Applicability
Accept	The right authority signs off residual risk.	Acceptance records

5 Risk criteria

5.1 Likelihood

Likelihood combines expected frequency with a threat-informed test: how common the technique is and how open the path is today.

Score	Label	Expected frequency	Threat-informed test
1	Rare	Less than once in ten years	Needs rare skill or several strong controls to fail together
2	Unlikely	Once in five to ten years	Possible, but at least one tested control stands in the way
3	Possible	Once in two to five years	Technique is in common use and controls are partial
4	Likely	About once a year	Technique is in common use and the path is mostly open
5	Almost certain	Several times a year, or already happening	Path is open today and needs little skill

5.2 Impact

Impact is rated on four dimensions, and the highest one sets the score. Financial bands are tied to FY2025 net revenue of EUR 21.4M.

Score	Label	Financial	Regulatory	Customer	Operational
1	Negligible	Under EUR 20k	No regulatory interest	No noticeable effect on customers	Payments degraded for under 15 minutes
2	Minor	EUR 20k to 100k	Informal query from a regulator	A few complaints; under 1% of customers affected	Payments unavailable for under 1 hour
3	Moderate	EUR 100k to 500k	Reportable incident or formal finding	Several merchants affected, or personal data of under 1,000 people exposed	Payments unavailable for 1 to 4 hours
4	Major	EUR 500k to 2M	Sanction or supervisory measures	Loss of an enterprise merchant, or data of thousands exposed	Payments unavailable for 4 to 24 hours
5	Severe	Over EUR 2M (about 10% of net revenue)	Licence restricted or put at risk	Widespread loss of trust, or most customer data exposed	Outage over 24 hours, or ledger integrity lost

5.3 Risk levels and appetite

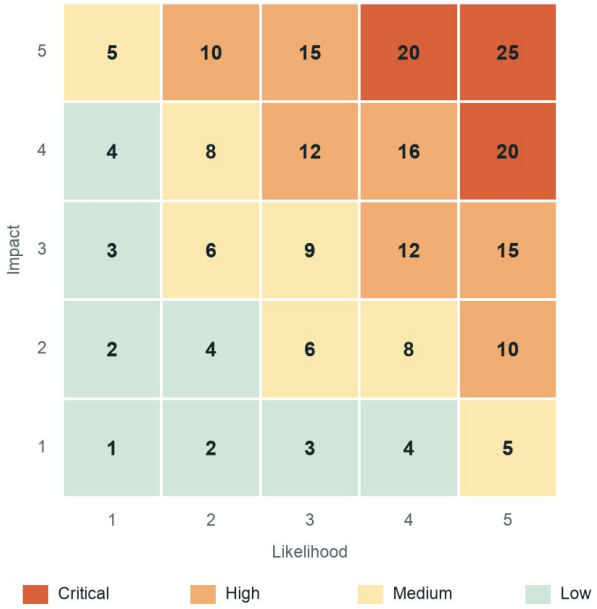


Figure 2: Risk matrix. Score is likelihood multiplied by impact.

Level	Score	Required response	Who may accept
Critical	17 to 25	Treat immediately. Acceptance only as a time-limited exception.	Management Board
High	10 to 16	Treatment plan required. Acceptance needs a written record.	CEO
Medium	5 to 9	Within appetite. Monitor and treat where cost is reasonable.	Risk owner
Low	1 to 4	Within appetite. Record and review yearly.	Risk owner

Risk appetite statement. Orvanta accepts risks scored 9 or lower when a named owner monitors them. It does not accept untreated High or Critical risks to customer funds, payment availability or customer data. Any exception is written, time-limited and reviewed.

6 Threat-informed analysis

Many risk registers score likelihood by instinct. Here, likelihood is tested against how an attack would actually proceed.

- **Threat catalog.** Each adversarial threat names the MITRE ATT&CK tactic and technique it relies on. Non-adversarial threats, such as outages and errors, are listed without a technique.
- **Attack scenarios.** The most serious risks are walked through step by step as a kill chain. For each step we ask which control would prevent it, detect it or respond to it.
- **Coverage status.** Each control at each step is rated Missing, Partial or Effective. Effective means working by design, and it stays provisional until tested by audit or exercise.
- **Three scores.** Inherent assumes no controls. Current counts controls that exist and work today. Target assumes the treatment plan is complete.

A step with no Effective prevent or detect control keeps likelihood at 4 or 5, whatever the paperwork says.

7 Treatment and acceptance

Option	When it is used	Example at Orvanta
Mitigate	Controls can reduce likelihood or impact at reasonable cost	Just-in-time admin access for AWS
Avoid	The activity or asset causing the risk can be removed	Retiring the legacy OpenVPN bastion
Transfer	Part of the financial impact can be shared	Cyber insurance for ransomware losses
Accept	The risk is within appetite, or treatment costs more than it saves	Single AWS region, accepted for a fixed period

Selected controls are compared with Annex A so that nothing necessary is missed, and the result feeds the Statement of Applicability. Acceptance above appetite needs a record stating the reason, conditions, expiry date and signatory.

8 Monitoring and review

- **Quarterly.** The Risk Manager reviews scores, action progress and expiring acceptances with each owner, and reports to the Management Board.
- **Yearly.** A full reassessment, including the asset register and threat catalog.
- **On change.** A new product, supplier, major architecture change, serious incident or new regulation triggers a targeted review.
- **Indicators.** Key risk indicators, such as MFA coverage and restore success, give early warning between reviews.

The workbook is the register of record. Earlier versions are kept for three years so that changes in risk can be traced.